

PRISM: ENTERPRISE RAG INTELLIGENCE SYSTEM

Secure, Context-Aware Knowledge Retrieval with Multi-Layered RBAC & RLS Guardrails

1. Problem Statement

Modern enterprises face massive data fragmentation across disconnected document folders, SQLite/CSV databases, and JSON logs. Retrieving answers from these sources using standard LLMs risks leaking sensitive information (e.g., salaries, M&A; strategy, audit details) to unauthorized employees. PRISM solves this by wrapping retrieval-augmented generation (RAG) in programmatic Role-Based Access Control (RBAC) and Row-Level Security (RLS) to enforce strict compliance on every query.

2. Core Architecture

PRISM processes queries through an integrated, multi-phase explainability pipeline: (1) **Identity Resolution**: Resolves the caller's credentials and corporate role; (2) **Sanitization & Defense**: Sanitizes queries and blocks prompt injection; (3) **Intent Query Routing**: Dynamically routes queries to relevant silos; (4) **Parallel Retrieval & RLS**: Programmatically checks silo RBAC and applies row-level clearance checks; (5) **Grounded LLM Synthesis**: Merges context and generates answers with inline citations [SOURCE N].

3. Multi-Layer Security Model

- **Silo-Level RBAC**: Access to databases, PDFs, and JSON audit files is guarded at the API boundary, restricting unauthorized roles entirely.
- **Row-Level Security (RLS)**: Filters rows/records where clearance level > user clearance, preventing exfiltration during context merging.
- **Jailbreak Protection**: Input filters detect prompt injection, blocking queries and logging attempts as security audit alerts.
- **Dynamic Role-Based Caching**: Keys query caches by role:clearance_level:query to prevent cross-department cache poisoning.
- **Append-Only Audit Log**: Generates a secure, persistent log on disk detailing the caller, routed sources, citations, and security status.

4. Data Sources and Clearance Compliance Matrix

Silo Type	Resource Identifier	Clearance	Permitted Roles
SQL Database	employees, salaries, contracts, compliance_records	Level 0 - 3	Executive, HR, Finance, IT Ops, Analyst
PDF Documents	compliance_report_2024.pdf, board_deck_Q3_2024.pdf	Level 2 - 3	Executive, Compliance, HR
PDF Documents	it_security_policy.pdf, Employee_Handbook_2026.pdf	Level 0 - 1	Executive, IT Ops, Analyst, Intern
CSV Spreadsheet	sales_kpi_2026.csv, compliance_records.csv	Level 1 - 3	Executive, Finance, Analyst, Compliance
JSON System Logs	system_logs.json, audit_trail.json, system_audit.json	Level 1 - 3	Executive, IT Operations, Compliance

5. Production-Grade Features

- **Hybrid Scoring**: Integrates TF-IDF and keyword sequence matching to retrieve highly relevant context snippets from PDF and CSV text.
- **Offline Fallback Mode**: Gracefully degrades to local rule-based database & handbook queries if Nvidia NIM API endpoints timeout or key is missing.
- **Rate Limiting & Safety**: Enforces Express-level endpoint rate-limits (30 requests/min) to prevent denial-of-service and brute force queries.
- **Explainability Dashboard**: An interactive dark-mode frontend featuring a data silo browser, a pipeline visualizer, live security metrics, and filterable audit trail logs.